

Security Audit Report

Project: mx-chain-simulator-go-dev-rwa DRWA / RWA Domain

Audit Type: Real-World Security Assessment DRWA Feature Branch

Executive Summary

This targeted security review identifies critical and high-severity vulnerabilities in the `mx-chain-simulator-go-dev-rwa` subsystem that pose an immediate threat to service availability, stability, and security. This report excludes general coding best practices and focuses exclusively on exploitable flaws.

Overall, 8 high-severity vulnerabilities were identified. These issues encompass remote denial-of-service vectors via memory and CPU exhaustion, fatal concurrency race conditions, and cross-site interaction risks. The merge is rejected until these real-world security threats are mitigated.

Tier	Count	Meaning
Critical / High	8	Must fix before any production deployment. Remote crashes, DoS, or security bypass.
Medium	0	-
Low / Informational	0	-

Overall Merge Status: REJECT -- 8 critical security threats identified.

Issue Index

#	Title	File	Location	Severity	Decision
1	Unbounded Resource Allocation on Validator API (CWE-400)	pkg/facade/simulatorFacade.go	L104	High	REJECT
2	Unconstrained Resource Allocation on State API (CWE-400)	pkg/proxy/api/endpointpoints.go	L285	High	REJECT
3	Unbounded CPU Consumption on Epoch API (CWE-400)	pkg/facade/simulatorFacade.go	L148	High	REJECT
4	Potential Panic on Uninitialized Simulator Components (CWE-476)	pkg/facade/simulatorFacade.go	L221	High	REJECT
5	Unprotected API Payload Buffer (CWE-400)	pkg/proxy/api/endpointpoints.go	L58	High	REJECT
6	Race Condition on Simulator State Access (CWE-362)	pkg/facade/simulatorFacade.go	L29	High	REJECT

#	Title	File	Location	Severity	Decision
7	Missing CORS Protection on Simulator API (CWE-942)	pkg/proxy/creator/creator.go	L201	High	REJECT
8	Denial of Service via Log Streaming (CWE-770)	pkg/proxy/api/enpoints.go	L86	High	REJECT

--

1. Unbounded Resource Allocation on Validator API

File: pkg/facade/simulatorFacade.go · **Line:** 104 **Severity:** High -- CWE-400 (Uncontrolled Resource Consumption)

What This Error Is

The API endpoint for adding validator keys does not enforce a limit on the number of keys submitted in a single request. An attacker can send a massive payload containing millions of keys, triggering an Out-of-Memory (OOM) crash as the Go runtime attempts to allocate the input slice.

2. Unconstrained Resource Allocation on State API

File: pkg/proxy/api/endpoints.go · **Line:** 285 **Severity:** High -- CWE-400 (Uncontrolled Resource Consumption)

What This Error Is

The `setStateMultiple` and `setStateMultipleOverwrite` endpoints accept an array of `AddressState` objects without length validation. Malicious requests containing extremely large arrays will cause immediate memory exhaustion and process termination.

3. Unbounded CPU Consumption on Epoch API

File: pkg/facade/simulatorFacade.go · **Line:** 148 **Severity:** High -- CWE-400 (Uncontrolled Resource Consumption)

What This Error Is

The `ForceChangeOfEpoch` function executes a loop that continues until the `currentEpoch` reaches a user-provided `targetEpoch`. An excessively large `targetEpoch` will lock the simulator in a tight CPU-bound loop, rendering it unresponsive.

4. Potential Panic on Uninitialized Simulator Components

File: pkg/facade/simulatorFacade.go · **Line:** 221 **Severity:** High -- CWE-476 (NULL Pointer Dereference)

What This Error Is

The `getCurrentEpoch` function performs deep nested property access without validating if intermediate handlers are initialized. An external API call made while the simulator is starting up or in an error state will trigger a Nil Pointer Dereference, crashing the process.

5. Unprotected API Payload Buffer

File: pkg/proxy/api/endpoints.go · **Line:** 58 **Severity:** High -- CWE-400 (Uncontrolled Resource Consumption)

What This Error Is

The simulator's API server does not enforce a global limit on the raw HTTP request body size. The framework buffers the entire request into memory before logical validation occurs, allowing attackers to crash the server by sending a multi-gigabyte payload to any POST endpoint.

6. Race Condition on Simulator State Access

File: pkg/facade/simulatorFacade.go · **Line:** 29 **Severity:** High -- CWE-362 (Race Condition)

What This Error Is

The `simulatorFacade` lacks synchronization primitives when accessing the shared simulator instance. Concurrent

API requests modifying state or generating blocks will lead to "concurrent map write" panics, which are fatal in Go and lead to immediate service termination.

7. Missing CORS Protection on Simulator API

File: pkg/proxy/creator/creator.go · **Line:** 201 **Severity:** High -- CWE-942 (Insecure CORS Configuration)

What This Error Is

The simulator API lacks a CORS policy. A malicious website visited by a developer can silently send cross-origin requests to the locally running simulator API (e.g., to /simulator/set-state) to corrupt simulation data or spike local resource usage.

8. Denial of Service via Log Streaming

File: pkg/proxy/api/endpoints.go · **Line:** 86 **Severity:** High -- CWE-770 (Allocation of Resources Without Limits)

What This Error Is

The /log WebSocket endpoint does not limit the number of concurrent connections. An attacker can open hundreds of log streams simultaneously to exhaust server bandwidth and CPU, rendering the simulator's management interface unusable.